

DREAD Risk Scoring, Worked Out by Hand

Threat triage needs a number, not a vibe. We score two concrete MCP threats across the five DREAD axes, turn the scores into priorities, and show the risk = likelihood × impact view.

What this document does. A threat model lists what could go wrong; DREAD ranks them so you fix the worst first. This document scores two real MCP threats across the five DREAD axes (Damage, Reproducibility, Exploitability, Affected users, Discoverability), averages them into a priority, and reconciles the result with the classic risk = likelihood × impact matrix.

Concepts covered: the five DREAD axes · a 1–10 rating scale · aggregate score and priority bands · ranking threats · likelihood × impact · why a single axis can dominate.

Internal learning material. Numbers reproducible from the appendix code. v1.0

1 The setup: two threats, five axes

We score two threats to an MCP server, each axis on 1–10:

- **T1 — Indirect prompt injection** through a poisoned wiki page that a `resources/read` pulls into context.
- **T2 — Verbose error leak** that returns a stack trace with an internal hostname.

Threat	D	R	E	A	Di	sum
T1 prompt injection	8	9	7	8	9	41
T2 error leak	3	8	6	4	5	26

Intuition

DREAD forces you to separate *how bad* from *how likely*. Damage and Affected users are impact; Reproducibility, Exploitability, and Discoverability are likelihood. A threat can be terrifying in damage but nearly impossible to trigger — scoring all five axes stops one scary word from dominating the decision.

2 Step 1 — Aggregate score and priority

The DREAD score is the average of the five axes:

$$\text{DREAD} = \frac{D + R + E + A + Di}{5}.$$

$$\text{T1} = \frac{41}{5} = 8.2, \quad \text{T2} = \frac{26}{5} = 5.2.$$

Map the average to priority bands:

[8, 10] **Critical**, [6, 8) **High**, [4, 6) **Medium**, [1, 4) **Low**.

So **T1 is Critical (8.2)** — fix now — and **T2 is Medium (5.2)** — schedule it. The ranking is unambiguous and defensible because it came from a rubric, not a hunch.

3 Step 2 — Risk as likelihood $\times$ impact

Group the axes: impact = $\frac{D+A}{2}$, likelihood = $\frac{R+E+Di}{3}$, and form risk = likelihood $\times$ impact on a 1–10 scale.

T1: impact = $\frac{8+8}{2} = 8.0$, likelihood = $\frac{9+7+9}{3} = 8.33$,

$$\text{risk} = \frac{8.0 \times 8.33}{10} = 6.67 \text{ (High-Critical).}$$

T2: impact = $\frac{3+4}{2} = 3.5$, likelihood = $\frac{8+6+5}{3} = 6.33$,

$$\text{risk} = \frac{3.5 \times 6.33}{10} = 2.22 \text{ (Low).}$$

Mini-example — this operation in isolation

The product punishes balance, not extremes. T2's likelihood (6.33) is respectable — it is easy to trigger — but its impact (3.5) is low, and 6.33×3.5 stays small. A threat needs *both* arms to be dangerous; either factor near zero drags the product down. That is the whole logic of a risk matrix.

Watch out

DREAD scores are subjective inputs — two engineers may rate Exploitability 6 vs 8. The number is only as good as the rubric behind each axis. Use DREAD to *rank* and *communicate*, not as a physical measurement. Calibrate the 1–10 anchors as a team, or the precision is an illusion.

4 The argument, at a glance

#	Idea	Formula	Value
1	DREAD average	$(D+R+E+A+Di)/5$	T1 8.2 / T2 5.2
1	Priority band	thresholds	Critical / Medium
2	Impact	$(D+A)/2$	T1 8.0
2	Likelihood	$(R+E+Di)/3$	T1 8.33
2	Risk	impact $\times$ likelihood / 10	T1 6.67 / T2 2.22

5 Equation cheat-sheet

DREAD score $(D+R+E+A+Di)/5$

Priority bands Crit [8, 10], High [6, 8), Med [4, 6), Low [1, 4)

Impact $(D+A)/2$

Likelihood $(R+E+Di)/3$

Risk impact $\times$ likelihood / 10

A Reference implementation

```
def dread(D, R, E, A, Di):  
    score = (D + R + E + A + Di) / 5  
    impact = (D + A) / 2  
    likelihood = (R + E + Di) / 3  
    risk = impact * likelihood / 10  
    return round(score,2), round(risk,2)  
  
print(dread(8, 9, 7, 8, 9))          # (8.2, 6.67) T1 Critical  
print(dread(3, 8, 6, 4, 5))          # (5.2, 2.22) T2 Medium/Low
```

— end of document —